

AWS WAF 고도화: 로그 분석 기반 Count → Block 전환

역할 전임자에게 인수받은 WAF 운영, 로그 분석, 차단 전환, 오탐 대응, 일일 리포트 자동화

환경 AWS WAF v2 (ALB 2대, Web ACL 2개), CloudWatch Logs Insights, Lambda, EventBridge, Confluence API

인수 시점 상태

- 수동 IP 차단 규칙 1개만 Block. 관리형 규칙 그룹을 포함한 나머지 규칙은 모두 Count(탐지만)
- 규칙 9개, WCU 1428. 두 Web ACL이 같은 규칙 구성
- 최종 목표는 차단이지만 어떤 규칙을 켜면 어떤 정상 트래픽이 끊기는지 판단할 근거가 없는 상태
- 첫 과제를 Count 로그 기반 영향도 정량화로 설정

분석 방법

- Logs Insights로 Web ACL별 로그를 따로 집계. 트래픽 성격이 달라 두 Web ACL을 합산하지 않는 원칙
- Count 상태 규칙 그룹도 `ruleGroupList[].terminatingRule` 에 원래 차단했을 하위 규칙 ID가 남는 점을 이용해 하위 규칙 단위로 영향 산출
- "지금 Block으로 바꾸면 끊길 요청"을 ALLOW + Count 매칭 조건으로 추출
- 헤더 배열 필터가 안 되는 제약은 상위 출처를 먼저 집계하고 해당 원본 로그만 소량 조회하는 2단계 방식으로 해결
- 모수가 작은 Web ACL(규칙 매칭 0.4%)보다 모수가 큰 쪽(매칭 84.4%)을 기준 분석 대상으로 선택

규칙별 판단

판단 기준: 정상 사용자나 내부 서비스가 섞였는지, 섞였다면 경로나 라벨로 예외 처리가 가능한지, 관찰 기간(1~3주) 동안 오탐이 없었는지.

규칙	매칭 성격	조치
국가 차단 (커스텀)	허용 국가 외 트래픽, 대부분 스캐너와 봇	1순위 Block
SQLiRuleSet	매칭 28건 전부 외부 스캐너의 공격 시도	Block
KnownBadInputs, LinuxRuleSet	취약 경로 탐색, 경로 순회 시도	Block
AmazonIpReputationList	7일 관찰 결과 매칭 전부 해외 취약점 스캔, 정상 사용자 0건	Block
CommonRuleSet	일부 하위 규칙에 정상 업로드와 에디터 입력 포함	그룹 Block, 하위 2종만 Count
AnonymousIpList, BotControl	내부 서비스 호출, 헬스체크, 파트너 앱 호출 포함	Count 유지

- 규칙 그룹 하나 때문에 그룹 전체를 포기하지 않도록, 문제 되는 하위 규칙만 `RuleAction0verrides` 로 Count 처리하고 나머지는 Block

오탐 대응

오차단 6건은 대부분 파일 업로드와 multipart 요청에서 발생. 공격과 구분한 근거는 User-Agent, 세션, 경로 일관성, 변경 시점 전후 비교.

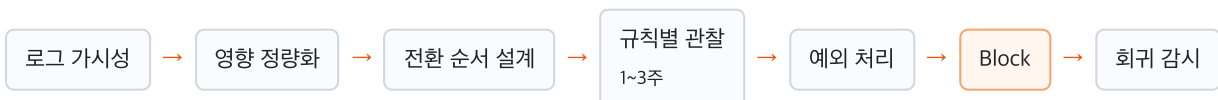
유형	원인	조치
바이너리 업로드가 경로 순회로 탐지	업로드 본문의 바이너리 구간이 LFI 시그니처와 일치, 1시간 40건 차단	IP 허용 방식이 유동 IP 파트너를 못 막아 경로 기반 예외로 전환
multipart 경계 문자열이 SQLi로 탐지	boundary와 Base64 패딩 문자 조합. 실제 사용자가 3회 재시도 후 실패	하위 규칙 Count, 업무 경로 제외 커스텀 규칙
앱 HTTP 라이브러리 교체 후 업로드 차단	boundary 형식이 바뀌어 본문이 SQL 주석과 비슷한 연속 문자로 시작	30일 로그를 교체 전후로 대조해 원인 확정, 라벨과 경로 조건 예외
사진 업로드 실패	XSS 본문 규칙 매칭	하위 규칙 Count, 본문 크기 상한 20MB → 30MB
사내 IP 업무 기능 403	같은 출처, 같은 요청의 Block 로그 확인	최우선순위 사내 IP 허용, 전용 알림 구축
앱스토어 심사 접속 차단	심사 접속 국가가 허용 국가 밖	국가 차단만 임시 Count. 원복 조건 기록

Custom Rule 6종

규칙	목적
본문 크기 상한	관리형 8KB 기준 대신 서비스 현실에 맞는 상한 초과만 차단
경로 순회 예외	내부 업로드는 통과, 외부의 실제 공격은 계속 차단
SQLi 예외 (업무 경로)	파트너 업무 기능과 SQLi 차단 동시 유지
SQLi 예외 (모바일 업로드)	클라이언트 라이브러리 변경에 따른 재발 방지
SQLi 우회 패턴 보강 (Block)	관리형 규칙이 놓친 변형을 디코딩, 주석 제거, 공백 정리, 소문자화 후 정규식으로 차단
SQLi 고민감도 (Count)	차단 전 오탐률 측정용 탐지

- 보강 계기: 쿼리 파라미터를 돌아가며 시도하는 자동화 SQLi 공격 중 일부가 관리형 규칙을 통과해 오리진까지 도달한 기록을 오리진 접근 로그 대조로 확인
- 우회 패턴 규칙은 적용 전 24시간 정상 트래픽에 매칭 0건 확인 후 Block. 적용 후 오탐 0건
- 고민감도 규칙은 광고 유입 파라미터 오탐 7건이 확인돼 Block 보류

Block 전환 절차



- 순서: 의도된 차단(국가) → 오탐 낮은 공격 탐지 규칙 → 평판 기반 → 정상 트래픽이 섞인 규칙은 예외 처리 후
- 임시 완화(Count 전환)는 반드시 원복 조건과 함께 기록

리포트와 알림 자동화

- 수동 HTML 보고서를 Lambda와 EventBridge로 자동화. 매일 자정 전날 24시간을 분석해 Confluence 페이지 생성
- 리포트 구성: 개요, 조치 필요 사항, Block 현황, Count 현황(전환 영향), 특수 사례, 공격 시도 요약, 국가 차단 요약
- Count 규칙을 "예외 필요 / 검토 필요 / 전환 가능"으로 자동 분류. 공격 유형은 경로와 규칙 ID로 7가지 라벨 부여

- 허용 목록 IP가 차단될 때만 올리는 알림: Metric Filter → Alarm → EventBridge → Lambda가 최근 차단 상세를 조회해 메신저로 전송, 복구 시 해제 알림

결과

항목	결과
규칙 구성	9개 → 15개 (Custom Rule 6종 포함)
Block 전환	국가 차단, 요청 빈도 제한, KnownBadInputs, SQLi, Linux, Common(하위 2종 제외), IP 평판
오탐	6건 원인 규명 후 규칙 재설계
리포트	매일 자동 생성

전환 후 차단 급증 알림 2건은 모두 평판 규칙이 해외 스캐너를 막은 결과로 확인. 서비스 영향 없음.

남은 작업

- AnonymousIpList, BotControl 전환 (내부 호출 허용 목록 선행)
- 임시 Count로 둔 국가 차단 원복, 두 Web ACL 간 규칙 구성 통일

공개용 문서. Web ACL과 로드밸런서 이름, IP, 예외 경로와 조건값, 도메인은 제외하고 목적만 표기.